

Goya Ledger Certificate Policy

OID: 1.3.6.1.4.1.99999.2.1 **Version:** 1.0.0 **Status:** Draft **Publication Date:** 2026-08-13 **Publication URL:** <https://goya.cl/pki/cp>

Table of Contents

1. [Introduction](#)
 2. [Publication and Repository Responsibilities](#)
 3. [Identification and Authentication](#)
 4. [Certificate Life-Cycle Operational Requirements](#)
 5. [Facility, Management, and Operational Controls](#)
 6. [Technical Security Controls](#)
 7. [Certificate, CRL, and OCSP Profiles](#)
 8. [Compliance Audit and Other Assessments](#)
 9. [Other Business and Legal Matters](#)
-

1. Introduction

1.1 Overview

This Certificate Policy (CP) establishes the requirements governing the issuance, management, use, suspension, revocation, and renewal of X.509 public-key certificates within the Goya Ledger Public Key Infrastructure (PKI). The policy applies to all certificates issued by the Goya Ledger Certification Authority (CA) hierarchy for the purposes of electronic signatures, electronic seals, and web authentication.

The Goya Ledger is a blockchain node platform built on Rust and Actix-Web 4 that provides an internal PKI for identity management, electronic signatures, and secure peer-to-peer communications. The PKI supports three classes of electronic signature under Chilean and European law:

- **Firma Electrónica Simple (FES):** Simple electronic signature using Ed25519, providing authentication and integrity without formal identity proofing.
- **Firma Electrónica Avanzada (FEA):** Advanced electronic signature using ML-DSA-65 (FIPS 204) with biometric evidence, providing non-repudiation and legal equivalence to handwritten signatures.

- **Electronic Seal:** Legal entity seal for organizational document integrity.

This CP is structured in accordance with RFC 3647 “Internet X.509 Public Key Infrastructure Certificate Policy and Certification Practices Framework” and addresses the requirements of:

- Chilean Ley 19.799 on Electronic Signatures
- Chilean Decreto Supremo 24/2019 (Norma Técnica FEA)
- Chilean Decreto Supremo 181/2002 (Reglamento Ley 19.799)
- European Regulation (EU) No 910/2014 (eIDAS)
- ETSI EN 319 411-1 (Policy and security requirements for TSPs issuing certificates – General requirements)
- ETSI EN 319 411-2 (Policy and security requirements for TSPs issuing QCerts)

1.2 Document Name and Identification

Attribute	Value
Document Title	Goya Ledger Certificate Policy
Document OID	1.3.6.1.4.1.99999.2.1
CPS OID	1.3.6.1.4.1.99999.2.2
TSA Policy OID	1.3.6.1.4.1.99999.1.1
Signature Policy OID	1.3.6.1.4.1.99999.3.1
OID Root Arc	1.3.6.1.4.1.99999 (Goya Private Enterprise Number)
Version	1.0.0
Status	Draft

The OID namespace is defined in `src/pki_policy.rs` (constants `G0YA_OID_ROOT`, `CP_OID`, `CPS_OID`, `TSA_POLICY_OID`, `SIGNATURE_POLICY_OID`).

All certificates issued under this policy SHALL include the CP OID `1.3.6.1.4.1.99999.2.1` in the X.509 `certificatePolicies` extension (OID `2.5.29.32`), with a CPS Pointer qualifier referencing `https://goya.cl/pki/cp`. This is enforced by the `certificate_policies_extension()` function in `src/pki.rs`.

1.3 PKI Participants

1.3.1 Certification Authorities

The Goya Ledger PKI employs a two-tier CA hierarchy implemented in `src/pki.rs`:

- **Root CA** (offline): Self-signed certificate with Common Name “Rust-BC Internal CA” (`INTERNAL_CA_CN`). The Root CA key is generated during a formal key ceremony and stored offline. The Root CA signs only Intermediate CA certificates. Validity: 10 years (2024-01-01 to 2034-01-01).

- **Intermediate CA** (operational): Certificate with Common Name “Goya Ledger Intermediate CA” (INTERMEDIATE_CA_CN), signed by the Root CA. The Intermediate CA performs all operational signing: node certificates, CRLs, and OCSP responses. Validity: 5 years from issuance. Path length constraint: 0 (cannot issue further CA certificates).

The `CaHierarchy` struct in `src/pki.rs` encapsulates this two-tier architecture, providing `root()` and `intermediate()` accessors and enforcing that node certificates are signed exclusively by the Intermediate CA.

1.3.2 Registration Authorities

The Registration Authority (RA) performs identity proofing before certificate issuance. The RA is implemented in `src/identity/ra.rs` as the `RaStore` module and operates under the requirements of Ley 19.799 Article 15.

RA functions include:

- Accepting identity proofing requests from subscribers
- Validating Chilean RUT (Rol Unico Tributario) via the modulo 11 algorithm (`validate_rut()`)
- Verifying legal name against official documents
- Approving or rejecting proofing requests
- Issuing certificates upon successful identity verification via `approve_and_issue_cert()`

RA officers are identified by their DID (`did:goya:{pubkey_hex[. .16]}`) and all RA decisions are recorded with the officer’s DID, timestamp, and disposition.

1.3.3 Subscribers

Subscribers are natural persons or legal entities that receive certificates under this policy. Subscribers are identified by their Decentralized Identifier (DID) in the format `did:goya:{pubkey_hex[. .16]}`, derived canonically via `identity::did::did_from_pubkey_hex()`.

1.3.4 Relying Parties

Relying parties are entities that use certificates issued under this policy to verify electronic signatures, seals, or TLS connections. Relying parties SHALL validate the certificate chain, check revocation status via CRL or OCSP, and verify that the certificate policy OID matches the intended use.

1.3.5 Other Participants

- **Timestamping Authority (TSA)**: Provides RFC 3161 timestamps under TSA Policy OID 1.3.6.1.4.1.9999.1.1.
- **OCSP Responder**: Provides real-time certificate status per RFC 6960.
- **Trusted Service List (TSL) Client**: Consults external trust lists per ETSI TS 119 612; implemented in `src/tsl.rs` and `src/tsl_client.rs`.

1.4 Certificate Usage

1.4.1 Appropriate Certificate Uses

This policy defines three certificate profiles, each corresponding to a CertProfileType enum variant in src/pki_policy.rs:

Profile	EN 319 412	QCType OID	Key Usage	Signature Level
NaturalPerson (esign)	EN 319 412-2	0.4.0.1862.1.6.1	digitalSignature, nonRepudiation	FES or FEA
LegalPerson (eseal)	EN 319 412-3	0.4.0.1862.1.6.2	digitalSignature, nonRepudiation	Seal
WebAuthentication (QWAC)	EN 319 412-4	0.4.0.1862.1.6.3	digitalSignature, keyEncipherment	TLS

Certificates SHALL be used only for the purposes indicated by their Key Usage and Extended Key Usage extensions.

1.4.2 Prohibited Certificate Uses

Certificates issued under this policy SHALL NOT be used for:

- Code signing (unless explicitly profiled)
- Encryption of data at rest
- Purposes inconsistent with the Key Usage extension
- Activities that violate applicable law

1.5 Policy Administration

1.5.1 Organization Administering the Document

Goya Ledger Project, operating under Chilean jurisdiction.

1.5.2 Contact Person

Policy inquiries shall be directed to the PKI Policy Authority via the contact mechanisms published at <https://goya.cl/pki/contact>.

1.5.3 Person Determining CPS Suitability for the Policy

The PKI Policy Authority shall determine whether a Certification Practice Statement conforms to this Certificate Policy.

1.5.4 CPS Approval Procedures

The CPS SHALL be reviewed and approved by the PKI Policy Authority prior to publication. Changes to the CPS SHALL be version-controlled and published at <https://goya.cl/pki/cps>.

1.6 Definitions and Acronyms

Term	Definition
CA	Certification Authority
CP	Certificate Policy
CPS	Certification Practice Statement
CRL	Certificate Revocation List
DID	Decentralized Identifier
FEA	Firma Electronica Avanzada (Advanced Electronic Signature)
FES	Firma Electronica Simple (Simple Electronic Signature)
HSM	Hardware Security Module
ML-DSA	Module-Lattice-Based Digital Signature Algorithm
OCSP	Online Certificate Status Protocol
PQC	Post-Quantum Cryptography
PSC	Prestador de Servicios de Certificacion
QWAC	Qualified Website Authentication Certificate
RA	Registration Authority
RUT	Rol Unico Tributario (Chilean tax identifier)
TSA	Timestamping Authority
TSL	Trusted Service List

2. Publication and Repository Responsibilities

2.1 Repositories

The CA SHALL maintain the following publicly accessible repositories:

Resource	Endpoint	Format
Certificate Policy	https://goya.cl/pki/cp	Markdown / PDF
Certification Practice Statement	https://goya.cl/pki/cps	Markdown / PDF
Certificate Revocation List	/api/v1/crl	DER (application/pkix-crl)
Certificate Revocation List	/api/v1/crl/pem	PEM (application/x-pem-file)

Resource	Endpoint	Format
OCSP Responder (JSON)	/api/v1/ocsp/query	JSON
OCSP Responder (DER)	/api/v1/ocsp/query/der	DER (application/ocsp-response)
OCSP Status	/api/v1/ocsp/status	JSON
CA Certificates	/api/v1/pki/ca	PEM

The CRL and OCSP endpoints are implemented in `src/api/handlers/ocsp.rs` and registered via `src/api/routes.rs`.

2.2 Publication of Certification Information

The CA SHALL publish:

1. This Certificate Policy and any updates thereto.
2. The current CPS.
3. All CA certificates in the hierarchy (root and intermediate).
4. Current CRLs, updated within one (1) hour of any revocation event, in accordance with DS 181 Article 17.
5. OCSP responder availability at the endpoints listed above.

2.3 Time or Frequency of Publication

- **CP/CPS:** Published upon approval and within seven (7) days of any material change.
- **CRL:** Published at least every twenty-four (24) hours and within one (1) hour of any revocation or suspension event. CRL validity is configurable; default is seven (7) days.
- **OCSP:** Available in real time via the API endpoints.

2.4 Access Controls on Repositories

- CP, CPS, CA certificates, CRLs, and OCSP responses SHALL be publicly accessible without authentication.
- Write access to repositories SHALL be restricted to authorized CA personnel.
- API access control is governed by the `ACL_MODE` configuration and enforced via `enforce_acl` middleware (`src/api/`).

3. Identification and Authentication

3.1 Naming

3.1.1 Types of Names

Certificates issued under this policy use X.500 Distinguished Names in the Subject field. The following name forms are supported:

- **Common Name (CN):** Subscriber's legal name (natural person) or organizational name (legal entity).
- **Organization (O):** Organization name for legal person and QWAC certificates.
- **Country (C):** ISO 3166-1 alpha-2 country code (e.g., "CL" for Chile).
- **Serial Number:** Chilean RUT for natural persons; RUT of the legal entity for organizational certificates.

Additionally, all subscribers are assigned a DID in the format `did:goya:{pubkey_hex[.16]}`, which serves as the internal canonical identifier. DID derivation is performed exclusively by `identity::did::did_from_pubkey_hex()` as specified in the codebase conventions.

3.1.2 Need for Names to Be Meaningful

The Distinguished Name in each certificate SHALL contain the subscriber's verified legal name or organizational name. Names SHALL correspond to the identity proofing records held by the RA.

3.1.3 Anonymity or Pseudonymity of Subscribers

Pseudonymous certificates are not issued under this policy. All certificate subjects SHALL be identified by their verified legal name or organizational name.

3.1.4 Rules for Interpreting Various Name Forms

Name forms SHALL be interpreted according to X.500 and the applicable ETSI EN 319 412 profile for the certificate type.

3.1.5 Uniqueness of Names

The combination of Subject Distinguished Name and issuing CA SHALL be unique across all active (non-revoked, non-expired) certificates. The DID provides an additional uniqueness guarantee within the Goya Ledger namespace.

3.1.6 Recognition, Authentication, and Role of Trademarks

The CA does not adjudicate trademark disputes. Subscribers SHALL not request certificates containing names that infringe upon the intellectual property rights of others.

3.2 Initial Identity Validation

3.2.1 Method to Prove Possession of Private Key

The subscriber SHALL demonstrate possession of the private key corresponding to the public key in the certificate request through one of the following:

- Signing the certificate request with the private key (PKCS#10 CSR).
- A challenge-response protocol during the RA interaction.

3.2.2 Authentication of Organization Identity

For LegalPerson (eseal) and WebAuthentication (QWAC) certificates, the RA SHALL verify:

1. Legal existence of the organization through official registry records.
2. Authorization of the requesting individual to act on behalf of the organization.
3. Chilean RUT of the legal entity via the modulo 11 validation algorithm (`validate_rut()` in `src/identity/ra.rs`).
4. Domain control for QWAC certificates via DNS or HTTP validation.

3.2.3 Authentication of Individual Identity

For NaturalPerson (esign) certificates, the RA SHALL verify subscriber identity using one of the following methods, as defined in `ProofingMethod` (`src/identity/ra.rs`):

Method	Description	Assurance Level
InPerson	Face-to-face verification with government-issued photo ID	High
VideoConference	Real-time video verification with document presentation	High
RemoteAutomated	Automated verification via a trusted electronic identity service	Medium

Identity proofing SHALL include:

1. Verification of Chilean RUT via the modulo 11 algorithm, accepting formats “12345678-5”, “12.345.678-5”, or “123456785” (as implemented by `validate_rut()`).
2. Verification of legal name against the presented identity document.
3. For FEA-level certificates: collection of biometric evidence as specified in Section 6.1.6.

The proofing lifecycle follows the state machine: Pending -> Verified | Rejected, as defined by `ProofingStatus` in `src/identity/ra.rs`.

3.2.4 Non-Verified Subscriber Information

Any subscriber information not verified by the RA SHALL NOT appear in the certificate Subject field. Non-verified information may be recorded in the RA's internal records but is not asserted by the CA.

3.2.5 Validation of Authority

For certificates issued to representatives of legal entities, the RA SHALL verify that the individual is authorized to request the certificate on behalf of the organization through documentation such as power of attorney, corporate resolution, or equivalent legal instrument.

3.2.6 Criteria for Interoperation

The CA MAY recognize certificates from external CAs for interoperation purposes, subject to policy mapping and cross-certification agreements. Trusted Service List (TSL) consultation is supported via the `src/tsl.rs` and `src/tsl_client.rs` modules.

3.3 Identification and Authentication for Re-Key Requests

3.3.1 Identification and Authentication for Routine Re-Key

Routine re-key (renewal) SHALL require the subscriber to authenticate using their current valid certificate or by repeating the initial identity validation process.

Certificate renewal generates a fresh key pair and new certificate while maintaining the same subscriber identity, as implemented by `renew_node_cert()` in `src/pki.rs`.

3.3.2 Identification and Authentication for Re-Key After Revocation

After revocation, the subscriber SHALL complete the full initial identity validation process (Section 3.2) before a new certificate is issued.

3.4 Identification and Authentication for Revocation Request

Revocation requests SHALL be authenticated by one of:

1. The subscriber using their private key to sign the revocation request.
 2. An authorized RA officer identified by DID.
 3. The CA acting on its own authority in cases of key compromise or policy violation.
-

4. Certificate Life-Cycle Operational Requirements

4.1 Certificate Application

4.1.1 Who Can Submit a Certificate Application

Certificate applications may be submitted by:

- Natural persons for NaturalPerson certificates.
- Authorized representatives of legal entities for LegalPerson or WebAuthentication certificates.
- Node operators for P2P TLS node certificates.

Applications are submitted to the RA via the `RaStore::submit()` method, which requires a DID, RUT, legal name, proofing method, and timestamp.

4.1.2 Enrollment Process and Responsibilities

The enrollment process consists of:

1. **Application Submission:** The subscriber submits identity information and proofing method preference to the RA.
2. **RUT Validation:** The RA validates the Chilean RUT using the modulo 11 algorithm.
3. **Identity Proofing:** The RA performs identity verification per the selected method.
4. **Approval/Rejection:** An RA officer approves or rejects the application, recording their DID and the disposition timestamp.
5. **Certificate Issuance:** Upon approval, the CA issues a certificate signed by the Intermediate CA.

The integrated workflow is available via `RaStore::approve_and_issue_cert()`, which atomically approves the proofing request and issues the certificate.

4.2 Certificate Application Processing

4.2.1 Performing Identification and Authentication Functions

The RA SHALL perform all identification and authentication functions described in Section 3.2 before approving a certificate application. The RA SHALL reject applications with:

- Invalid or mismatched RUT check digits.
- Expired or unacceptable identity documents.
- Insufficient evidence for the requested assurance level.

Rejection reasons are recorded in the `IdentityProofing.rejection_reason` field.

4.2.2 Approval or Rejection of Certificate Applications

Certificate applications SHALL be approved only when all identification and authentication requirements have been satisfied. The RA officer's DID and the resolution timestamp are recorded for audit purposes.

A pending application cannot be approved or rejected more than once; the system enforces this constraint through status checking (`ProofingStatus::Pending` is required).

4.2.3 Time to Process Certificate Applications

Certificate applications SHALL be processed within five (5) business days of submission, subject to successful completion of identity proofing.

4.3 Certificate Issuance

4.3.1 CA Actions During Certificate Issuance

Upon receiving an approved certificate request from the RA, the CA SHALL:

1. Generate a fresh ECDSA P-256 key pair for the subscriber (`KeyPair::generate()` in `src/pki.rs`).
2. Construct the certificate with the verified Subject DN and appropriate extensions.
3. Embed the `certificatePolicies` extension with OID `1.3.6.1.4.1.99999.2.1` and CPS pointer.
4. For qualified certificates: embed the `QCStatements` extension per EN 319 412-5 using `qc_statements_extension()`.
5. Sign the certificate using the Intermediate CA key.
6. Return the issued certificate in both DER and PEM formats (`IssuedNodeCert`).

4.3.2 Notification to Subscriber by the CA of Issuance of Certificate

The subscriber SHALL be notified of certificate issuance through the API response containing the certificate PEM and key PEM.

4.4 Certificate Acceptance

4.4.1 Conduct Constituting Certificate Acceptance

The subscriber is deemed to have accepted the certificate upon first use of the associated private key for signing or authentication.

4.4.2 Publication of the Certificate by the CA

Issued certificates are not published in a public directory by default. The CA certificate chain is published at `/api/v1/pki/ca`.

4.4.3 Notification of Certificate Issuance by the CA to Other Entities

No stipulation.

4.5 Key Pair and Certificate Usage

4.5.1 Subscriber Private Key and Certificate Usage

Subscribers SHALL:

1. Protect the private key from unauthorized access and disclosure.
2. Use the certificate only for the purposes indicated by the Key Usage extension.
3. Report suspected or confirmed key compromise to the CA within twenty-four (24) hours.
4. Cease using the certificate upon revocation or expiration.
5. Provide accurate identity information to the RA.

4.5.2 Relying Party Public Key and Certificate Usage

Relying parties SHALL:

1. Validate the certificate chain to a trusted root.
2. Check the certificate's revocation status via CRL or OCSP before reliance.
3. Verify that the certificate policy OID matches the intended use.
4. Verify that the certificate has not expired.

Chain validation is implemented in `src/pki_chain.rs`, which performs DER/PEM parsing, validity period checking, issuer-subject chain linking, trust anchor verification, and CA basic constraint validation.

4.6 Certificate Renewal

Certificate renewal follows the same process as initial issuance but may use the existing valid certificate for authentication. The `renew_node_cert()` function in `src/pki.rs` generates a fresh key pair with a new validity period for the same node identity.

The old certificate SHOULD be revoked prior to or concurrently with renewal via `LifecycleManager::revoke_and_publish_crl()` (see `src/pki_lifecycle.rs`).

4.7 Certificate Re-Key

Re-key follows the same procedures as renewal (Section 4.6). A new key pair is always generated; key reuse is not supported.

4.8 Certificate Modification

Certificate modification (changing subject attributes without re-key) is not supported. Any change to certificate attributes requires a new certificate issuance following the procedures in Section 4.1 through 4.3.

4.9 Certificate Revocation and Suspension

4.9.1 Circumstances for Revocation

A certificate SHALL be revoked when:

1. The subscriber's private key is compromised or suspected of compromise.
2. The information in the certificate is no longer accurate.
3. The subscriber has violated the obligations of this policy.
4. The CA is informed that the subscriber was not authorized to obtain the certificate.
5. The CA ceases operations.
6. The subscriber requests revocation.

4.9.2 Who Can Request Revocation

Revocation may be requested by:

- The subscriber (certificate holder).
- An authorized RA officer.
- The CA acting on its own authority.

4.9.3 Procedure for Revocation Request

Revocation is processed through the `LifecycleManager::revoke_and_publish_crl()` method in `src/pki_lifecycle.rs`, which:

1. Marks the certificate serial as revoked in the MSP (`Msp::revoke()`).
2. Persists the revocation to the CRL store.
3. Records a `CertificateRevoked` lifecycle event with the serial, MSP ID, and timestamp.
4. Immediately publishes an updated CRL signed by the CA.

4.9.4 Revocation Request Grace Period

There is no grace period. Revocation requests SHALL be processed immediately upon receipt.

4.9.5 Time Within Which CA Must Process the Revocation Request

The CA SHALL process revocation requests and publish an updated CRL within one (1) hour of receiving the request, in compliance with DS 181 Article 17.

4.9.6 Revocation Checking Requirement for Relying Parties

Relying parties SHALL check the revocation status of certificates using CRL or OCSP before relying on any certificate issued under this policy.

4.9.7 CRL Issuance Frequency

CRLs SHALL be issued:

- At least every twenty-four (24) hours.
- Within one (1) hour of any revocation or suspension event.

CRL numbers are monotonically increasing, managed by the `LifecycleManager.crl_number` atomic counter.

4.9.8 Maximum Latency for CRLs

CRLs SHALL be available at the distribution points within ten (10) minutes of generation.

4.9.9 On-Line Revocation/Status Checking Availability

OCSP is available via:

- `/api/v1/ocsp/query` (JSON request/response)
- `/api/v1/ocsp/query/der` (DER-encoded request/response per RFC 6960)
- `/api/v1/ocsp/status` (responder health check)

OCSP responses are signed by the CA and provide real-time certificate status.

4.9.10 On-Line Revocation Checking Requirements

Relying parties SHOULD use OCSP for real-time status checks. CRL checking is an acceptable alternative.

4.9.11 Other Forms of Revocation Advertisements Available

No additional revocation advertisement mechanisms are currently defined.

4.9.12 Special Requirements Re Key Compromise

Upon confirmed key compromise, the CA SHALL:

1. Revoke the affected certificate immediately.
2. Publish an updated CRL within one (1) hour.
3. Notify the subscriber of the revocation.
4. Record the compromise event in the audit log.

4.9.13 Circumstances for Suspension

A certificate MAY be suspended (placed on hold) when:

1. There is a suspected but unconfirmed key compromise.
2. An investigation into subscriber conduct is underway.
3. The subscriber requests temporary suspension.

Suspension is implemented via

`LifecycleManager::suspend_and_publish_crl()`, which:

1. Marks the certificate as suspended in the MSP (`Msp::suspend()`).
2. Publishes the suspended serial in the CRL with reason code `certificateHold`.
3. Records a `CertificateSuspended` lifecycle event.

4.9.14 Who Can Request Suspension

Suspension may be requested by the subscriber, an RA officer, or the CA.

4.9.15 Procedure for Suspension Request

Suspension follows the same authenticated request process as revocation. A suspended certificate may be reinstated via

`LifecycleManager::reinstate_and_publish_crl()`, which removes the serial from the suspended list and publishes an updated CRL. A `CertificateReinstated` lifecycle event is recorded.

Note: A revoked certificate cannot be suspended or reinstated; the system enforces this constraint.

4.9.16 Limits on Suspension Period

Suspended certificates SHALL be either reinstated or revoked within thirty (30) days. If no action is taken within this period, the certificate SHALL be automatically revoked.

4.10 Certificate Status Services

4.10.1 Operational Characteristics

The OCSF responder provides real-time certificate status information. The responder is implemented in `src/msp/ocsp.rs` and `src/msp/ocsp_der.rs`, with API handlers in `src/api/handlers/ocsp.rs`.

4.10.2 Service Availability

The OCSF and CRL services SHALL be available twenty-four (24) hours a day, seven (7) days a week, with a target availability of 99.5%.

4.10.3 Optional Features

No stipulation.

4.11 End of Subscription

When a subscription ends, the subscriber SHALL:

1. Cease using the private key and certificate.
2. Destroy all copies of the private key.
3. The CA SHALL revoke any outstanding certificates.

4.12 Key Escrow and Recovery

4.12.1 Key Escrow and Recovery Policy and Practices

CA private keys are subject to split custody via M-of-N Shamir secret sharing, as defined in the key ceremony procedures (Section 5.2). Default configuration: 2-of-3 threshold (CeremonyConfig in `src/pki_ceremony.rs`).

Subscriber private keys are NOT escrowed. Key recovery is not supported for subscriber keys.

4.12.2 Session Key Encapsulation and Recovery Policy and Practices

Not applicable.

5. Facility, Management, and Operational Controls

5.1 Physical Controls

5.1.1 Site Location and Construction

The Root CA key ceremony SHALL be conducted in a physically secure, access-controlled environment. The ceremony environment is verified via the EnvironmentCheck step in the key ceremony procedure (`src/pki_ceremony.rs`).

5.1.2 Physical Access

Access to CA systems SHALL be restricted to authorized personnel. Multi-person access control SHALL be enforced for the Root CA.

5.1.3 Power and Air Conditioning

CA systems SHALL be provisioned with uninterruptible power supplies and environmental controls appropriate for continuous operation.

5.1.4 Water Exposures

CA facilities SHALL be protected against water damage.

5.1.5 Fire Prevention and Protection

CA facilities SHALL be equipped with fire detection and suppression systems.

5.1.6 Media Storage

Cryptographic media containing CA private keys or key shares SHALL be stored in fire-rated safes at geographically separated locations.

5.1.7 Waste Disposal

Media containing sensitive key material SHALL be destroyed using methods that prevent recovery (e.g., physical destruction, degaussing, or cryptographic erasure).

5.1.8 Off-Site Backup

Encrypted backups of CA configuration and certificate databases SHALL be maintained at a geographically separated facility.

5.2 Procedural Controls

5.2.1 Trusted Roles

The following trusted roles are defined, corresponding to the CeremonyRole enum in src/pki_ceremony.rs:

Role	Responsibility
Administrator	Leads the key ceremony and manages CA operations
Custodian	Holds a share of the split CA private key
Witness	Independently observes and attests to ceremony proceedings
Auditor	Verifies compliance with this CP and the CPS
Notary	Provides legal attestation of the ceremony

5.2.2 Number of Persons Required per Task

- **Root CA Key Ceremony:** Minimum of one (1) Administrator, three (3) Custodians, two (2) Witnesses, and one (1) Notary (when notary_required is true). These minimums are enforced by KeyCeremony::validate().
- **Intermediate CA Operations:** Minimum of two (2) authorized personnel.

- **Certificate Issuance:** One (1) RA officer for approval; the CA signs automatically.
- **Revocation:** One (1) authorized RA officer or the subscriber.

5.2.3 Identification and Authentication for Each Role

All participants in trusted roles SHALL be identified by their legal name and, where applicable, their DID. Ceremony participants are recorded in the CeremonyParticipant struct with name, role, DID, and organization.

5.2.4 Roles Requiring Separation of Duties

The following separation of duties SHALL be enforced:

- The Administrator SHALL NOT serve as a Custodian.
- No single person SHALL hold more than one Custodian share.
- The Auditor SHALL be independent of the CA operational team.

5.3 Personnel Controls

5.3.1 Qualifications, Experience, and Clearance Requirements

Personnel in trusted roles SHALL possess appropriate qualifications and experience in PKI operations and information security.

5.3.2 Background Check Procedures

Background checks SHALL be conducted for all personnel in trusted roles.

5.3.3 Training Requirements

Personnel SHALL complete training on PKI operations, this CP, the CPS, and applicable legal requirements before assuming trusted roles.

5.3.4 Retraining Frequency and Requirements

Retraining SHALL be conducted annually and upon material changes to the CP or CPS.

5.3.5 Job Rotation Frequency and Sequence

No stipulation.

5.3.6 Sanctions for Unauthorized Actions

Unauthorized actions by personnel in trusted roles SHALL result in immediate suspension of access and investigation.

5.3.7 Independent Contractor Requirements

Independent contractors performing trusted roles SHALL be subject to the same controls as employees.

5.3.8 Documentation Supplied to Personnel

All personnel in trusted roles SHALL receive copies of this CP, the CPS, and operational procedures.

5.4 Audit Logging Procedures

5.4.1 Types of Events Recorded

The following events SHALL be recorded in the audit log, corresponding to LifecycleEventType in src/pki_lifecycle.rs:

- CRL publication (CrlPublished)
- Certificate suspension (CertificateSuspended)
- Certificate reinstatement (CertificateReinstated)
- Certificate revocation (CertificateRevoked)
- Certificate expiry warnings (CertificateExpiring)
- Certificate renewal (CertificateRenewed)

Additional events recorded by the audit subsystem (src/audit.rs):

- CA key generation and ceremony proceedings
- RA identity proofing decisions (approve/reject)
- Configuration changes
- Access control events
- All API requests affecting certificate lifecycle

5.4.2 Frequency of Processing Log

Audit logs SHALL be reviewed at least monthly by the Auditor. Automated monitoring SHALL alert on anomalous events in real time.

5.4.3 Retention Period for Audit Log

Audit logs SHALL be retained for seven (7) years, in compliance with Chilean record retention requirements.

5.4.4 Protection of Audit Log

Audit logs SHALL be stored in an append-only format with tamper evidence. When STORAGE_BACKEND=rocksdb is configured, audit logs are persisted to RocksDB.

5.4.5 Audit Log Backup Procedures

Audit logs SHALL be backed up at least daily to a separate storage system.

5.4.6 Audit Collection System (Internal vs. External)

The audit collection system is internal, implemented in `src/audit.rs`. Lifecycle events are collected by the `LifecycleManager.events` vector in `src/pki_lifecycle.rs`.

5.4.7 Notification to Event-Causing Subject

No stipulation.

5.4.8 Vulnerability Assessments

Vulnerability assessments SHALL be conducted at least annually.

5.5 Records Archival

5.5.1 Types of Records Archived

All certificate lifecycle records, RA identity proofing records, key ceremony records, audit logs, and CP/CPS documents SHALL be archived.

5.5.2 Retention Period for Archive

Records SHALL be retained for seven (7) years from the date of creation.

5.5.3 Protection of Archive

Archived records SHALL be protected against unauthorized access, modification, and destruction.

5.5.4 Archive Backup Procedures

Archives SHALL be backed up to geographically separated facilities.

5.5.5 Requirements for Time-Stamping of Records

All archived records SHALL include a timestamp from a trusted time source. The TSA (under OID 1.3.6.1.4.1.99999.1.1) provides RFC 3161 timestamps for critical records.

5.5.6 Archive Collection System (Internal or External)

Internal.

5.5.7 Procedures to Obtain and Verify Archive Information

Archive records SHALL be retrievable by authorized personnel and verifiable through their associated integrity hashes.

5.6 Key Changeover

When a CA key approaches the end of its operational period, the CA SHALL:

1. Generate a new CA key pair through a formal key ceremony.
2. Continue signing CRLs and OCSP responses with the old key until all certificates signed by it have expired or been revoked.
3. Publish the new CA certificate for distribution to relying parties.

5.7 Compromise and Disaster Recovery

5.7.1 Incident and Compromise Handling Procedures

Upon detection of a CA key compromise:

1. Cease all certificate issuance immediately.
2. Revoke all certificates signed by the compromised key.
3. Notify all subscribers and relying parties.
4. Conduct a key ceremony to establish a new CA key.
5. Report the incident to the supervisory body (Entidad Acreditadora).

5.7.2 Computing Resources, Software, and/or Data Are Corrupted

The CA SHALL maintain disaster recovery procedures including checkpoint/snapshot mechanisms with persistent logs.

5.7.3 Entity Private Key Compromise Procedures

See Section 5.7.1.

5.7.4 Business Continuity Capabilities After a Disaster

The CA SHALL maintain a business continuity plan that ensures resumption of critical services within forty-eight (48) hours.

5.8 CA or RA Termination

Upon termination of CA or RA operations:

1. All subscribers SHALL be notified at least ninety (90) days in advance.
 2. All outstanding certificates SHALL be revoked.
 3. Final CRLs SHALL be published with a long validity period.
 4. All records SHALL be transferred to a successor entity or archived per Section 5.5.
 5. CA private keys SHALL be securely destroyed.
-

6. Technical Security Controls

6.1 Key Pair Generation and Installation

6.1.1 Key Pair Generation

CA Keys: CA key pairs SHALL be generated during a formal key ceremony (`src/pki_ceremony.rs`) in a secure environment. The ceremony follows these mandatory steps, enforced by `KeyCeremony::validate()`:

1. `EnvironmentCheck` – Verify air-gapped, physically secure environment.
2. `KeyGeneration` – Generate CA key pair using approved algorithms.
3. `WitnessAttestation` – Witnesses attest to proper procedure.
4. `KeySplit` – Split private key into custodian shares (M-of-N Shamir).
5. `ShareDistribution` – Distribute shares to separate secure locations.
6. `KeyVerification` – Verify public key and certificate correctness.
7. `Activation` – Activate the CA for operational use.

The ceremony record is integrity-protected with a SHA-256 hash (`compute_record_hash()`) and can be verified via `verify_record()`.

Subscriber Keys: Subscriber key pairs are generated using the operating system's cryptographically secure pseudorandom number generator (CSPRNG) via `KeyPair::generate()` in `src/pki.rs`. Each certificate issuance generates a fresh key pair; key reuse across certificates is prohibited.

6.1.2 Private Key Delivery to Subscriber

Subscriber private keys are generated locally and delivered to the subscriber in PEM format via the API response. Private keys are NEVER transmitted over unencrypted channels.

6.1.3 Public Key Delivery to Certificate Issuer

The public key is transmitted to the CA as part of the certificate signing request process, handled internally by the `sign_node_cert()` function.

6.1.4 CA Public Key Delivery to Relying Parties

CA public keys are available via:

- The `/api/v1/pki/ca` API endpoint (PEM format).
- The CPS publication URL.
- Direct distribution during node provisioning (`provision_node_cert_if_absent()`).

6.1.5 Key Sizes

The following key sizes and algorithms are supported:

Algorithm	Key Size	Standard	Use
Ed25519	256-bit	FIPS 186-5	FES subscriber signatures
ML-DSA-65	NIST Level 3	FIPS 204	FEA subscriber signatures (post-quantum)
ECDSA P-256	256-bit	FIPS 186-4	CA certificates, node TLS certificates
RSA	2048-bit minimum	FIPS 186-4	Legacy compatibility (where required)

Key size requirements are defined in `src/pki_policy.rs` (`KeyManagementPolicy.min_key_sizes`). Signatures are stored as `Vec<u8>` to accommodate variable-length outputs: Ed25519 (64 bytes) and ML-DSA-65 (3309 bytes). Hex serialization is performed via the `vec_hex` serde helper.

6.1.6 Public Key Parameters Generation and Quality Checking

Public key parameters SHALL be generated using approved algorithms and validated for correctness before certificate issuance.

For FEA-level certificates, biometric evidence is required. The `BiometricEvidence` struct (`src/signature/mod.rs`) captures:

- Biometric modality (e.g., fingerprint, facial recognition)
- Evidence hash (integrity of the biometric sample)
- Capture timestamp
- Quality score

Biometric validation is enforced by `validate_fes_fea()` in `src/signature/mod.rs`.

6.1.7 Key Usage Purposes (as per X.509 v3 Key Usage Field)

Certificate Profile	Key Usage	Extended Key Usage
NaturalPerson (FES)	digitalSignature	id-kp-emailProtection
NaturalPerson (FEA)	digitalSignature, nonRepudiation	id-kp-emailProtection
LegalPerson (Seal)	digitalSignature, nonRepudiation	—
WebAuthentication (QWAC)	digitalSignature, keyEncipherment	id-kp-serverAuth, id-kp-clientAuth
CA Certificate	keyCertSign, cRLSign	—

6.2 Private Key Protection and Cryptographic Module Engineering Controls

6.2.1 Cryptographic Module Standards and Controls

Cryptographic operations are centralized in `crates/pqc_crypto_module/`, the FIPS-oriented cryptographic module. Direct imports of `sha2`, `ed25519_dalek`, or other low-level cryptographic crates in `src/` are forbidden; this boundary is enforced by `cargo test --test crypto_boundary`.

The cryptographic module is prepared for FIPS 140-3 Level 1 validation.

6.2.2 Private Key (N out of M) Multi-Person Control

CA private keys are protected by M-of-N split custody:

- **Threshold (M):** 2 (minimum shares required for reconstruction)
- **Total shares (N):** 3

These defaults are defined in `CeremonyConfig::default()` in `src/pki_ceremony.rs`.

6.2.3 Private Key Escrow

CA private keys are escrowed via split custody (Section 6.2.2). Subscriber private keys are NOT escrowed.

6.2.4 Private Key Backup

CA private key backup is performed through the split custody mechanism. HSM-based backup is planned for production deployment.

6.2.5 Private Key Archival

CA private keys SHALL NOT be archived beyond the split custody mechanism. Private keys SHALL be securely destroyed upon expiration of the associated CA certificate.

6.2.6 Private Key Transfer Into or From a Cryptographic Module

Private key import/export is supported via PEM format for operational purposes (`NodeCaConfig::from_pem_files()`). Key material in transit SHALL be encrypted.

6.2.7 Private Key Storage on Cryptographic Module

In-memory storage with `ZeroizeOnDrop` ensures that private key material is erased from memory when no longer needed. HSM storage via PKCS#11 is planned.

Memory locking (`mlock`) is used where supported to prevent key material from being swapped to disk.

6.2.8 Method of Activating Private Key

CA private key activation requires:

1. Reconstruction from M-of-N custodian shares (for the Root CA).
2. Loading from PEM files secured by the operating system’s access controls (for the Intermediate CA, via `TLS_CA_CERT_PATH` and `TLS_CA_KEY_PATH` environment variables).

6.2.9 Method of Deactivating Private Key

Private keys are deactivated by zeroing the memory contents via `ZeroizeOnDrop`. Upon process termination, all key material is erased.

6.2.10 Method of Destroying Private Key

Private keys SHALL be destroyed by:

1. Zeroing all in-memory copies.
2. Securely erasing all on-disk copies.
3. Destroying all physical media containing key shares.

6.2.11 Cryptographic Module Rating

The `pqc_crypto_module` crate is prepared for FIPS 140-3 Level 1 evaluation but has not yet been validated.

6.3 Other Aspects of Key Pair Management

6.3.1 Public Key Archival

CA public keys (certificates) SHALL be archived for the retention period specified in Section 5.5.

6.3.2 Certificate Operational Periods and Key Pair Usage Periods

Certificate Type	Validity Period
Root CA	10 years (2024-01-01 to 2034-01-01)
Intermediate CA	5 years from issuance
Subscriber (default)	365 days (configurable via <code>cert_ttl_days</code> parameter)
TSA Signing	730 days

6.4 Activation Data

6.4.1 Activation Data Generation and Installation

Activation data (e.g., custodian PINs, HSM credentials) SHALL be generated using a CSPRNG and distributed securely to authorized personnel.

6.4.2 Activation Data Protection

Activation data SHALL be protected in accordance with the sensitivity of the associated key material.

6.4.3 Other Aspects of Activation Data

No stipulation.

6.5 Computer Security Controls

6.5.1 Specific Computer Security Technical Requirements

CA systems SHALL implement:

- Operating system hardening.
- Role-based access control.
- Audit logging of all administrative actions.
- Network segmentation isolating CA systems.
- TLS encryption for all network communications (enforced in production via TLS_CERT_PATH/TLS_KEY_PATH).

6.5.2 Computer Security Rating

No stipulation.

6.6 Life Cycle Technical Controls

6.6.1 System Development Controls

The Goya Ledger codebase uses the Rust nightly toolchain (configured via `rust-toolchain.toml`) with mandatory quality gates:

- `cargo fmt --check` (formatting)
- `cargo clippy -- -D warnings` (linting with zero warnings)
- `cargo test --lib` (unit tests)
- `cargo test --test crypto_boundary` (cryptographic boundary enforcement)

6.6.2 Security Management Controls

Configuration is managed via environment variables documented in docs/api/configuration-guide.md. Production environment (RUST_BC_ENV=production) enforces TLS and warns on permissive ACL modes.

6.6.3 Life Cycle Security Controls

Version control, code review, and automated testing are required for all changes to PKI-related modules.

6.7 Network Security Controls

- P2P communications use TCP/TLS (src/network/).
- API communications use HTTPS in production.
- CORS is configurable via CORS_ALLOWED_ORIGINS.
- Rate limiting is enforced via RATE_LIMIT_RPS/RPM/RPH.
- Request timeouts are configurable via HTTP_REQUEST_TIMEOUT_SECS.

6.8 Time-Stamping

The TSA provides RFC 3161 timestamps under policy OID 1.3.6.1.4.1.99999.1.1. All certificate lifecycle events include Unix timestamps for auditability.

7. Certificate, CRL, and OCSP Profiles

7.1 Certificate Profile

7.1.1 Version Number

All certificates SHALL be X.509 Version 3.

7.1.2 Certificate Extensions

The following extensions are included in certificates issued under this policy:

Extension	OID	Critical	Description
Authority Key Identifier	2.5.29.35	No	Identifies the issuing CA key
Subject Key Identifier	2.5.29.14	No	Identifies the subject's public key
Key Usage	2.5.29.15	Yes	Per certificate profile (Section 6.1.7)
Basic Constraints	2.5.29.19	Yes	

Extension	OID	Critical	Description
			CA: true for CA certs; absent or false for end- entity OID 1.3.6.1.4.1.99999.2.1 with CPS pointer
Certificate Policies	2.5.29.32	No	
Subject Alternative Name	2.5.29.17	No	DNS name for node/ QWAC certs
CRL Distribution Points	2.5.29.31	No	/api/v1/crl
Authority Info Access	1.3.6.1.5.5.7.1.1	No	OCSP: /api/v1/ocsp/ query/der
QCStatements	1.3.6.1.5.5.7.1.3	No	Per EN 319 412-5 (qualified certs only)

7.1.3 QCStatements Extension

For qualified certificates, the QCStatements extension is constructed by `build_qc_statements_der()` and `qc_statements_extension()` in `src/pki.rs`, containing:

1. **QcCompliance** (OID `0.4.0.1862.1.1`): Declares the certificate as a qualified certificate under EN 319 412-5.
2. **QcType** (OID `0.4.0.1862.1.6`): Indicates the certificate type:
 - `0.4.0.1862.1.6.1` (id-etsi-qct-esign) for NaturalPerson electronic signatures
 - `0.4.0.1862.1.6.2` (id-etsi-qct-eseal) for LegalPerson electronic seals
 - `0.4.0.1862.1.6.3` (id-etsi-qct-web) for WebAuthentication (QWAC)

These OIDs are defined as constants in `src/pki_policy.rs` (`QC_COMPLIANCE_OID`, `QC_TYPE_OID`, `QCT_ESIGN_OID`, `QCT_ESEAL_OID`, `QCT_WEB_OID`).

7.1.4 Algorithm Object Identifiers

Algorithm	OID
ECDSA with SHA-256 (P-256)	1.2.840.10045.4.3.2
Ed25519	1.3.101.112
ML-DSA-65	Per FIPS 204 assignment
RSA with SHA-256	1.2.840.113549.1.1.11

7.1.5 Name Forms

See Section 3.1.

7.1.6 Name Constraints

The Intermediate CA certificate includes a path length constraint of 0 (`BasicConstraints::Constrained(0)`), preventing it from issuing further CA certificates.

7.1.7 Certificate Policy Object Identifier

All certificates SHALL include the `certificatePolicies` extension with OID `1.3.6.1.4.1.99999.2.1` and a CPS qualifier pointing to `https://goya.cl/pki/cp`.

7.1.8 Usage of Policy Constraints Extension

No stipulation.

7.1.9 Policy Qualifiers Syntax and Semantics

The CPS Pointer qualifier contains the URI `https://goya.cl/pki/cp` pointing to this Certificate Policy. The qualifier is encoded as an IA5String within the policy qualifier info sequence.

7.1.10 Processing Semantics for the Critical Certificate Policies Extension

The `certificatePolicies` extension is marked as non-critical. Relying parties SHOULD process this extension to verify policy compliance.

7.2 CRL Profile

7.2.1 Version Number

CRLs SHALL conform to X.509 Version 2 (RFC 5280).

7.2.2 CRL and CRL Entry Extensions

CRLs include:

- **CRL Number:** Monotonically increasing integer (`LifecycleManager.crl_number`).
- **Authority Key Identifier:** Identifies the signing CA key.
- **Issuing Distribution Point:** `/api/v1/crl`.

CRL entry extensions:

- **Reason Code:** Indicates the reason for revocation (e.g., `keyCompromise`, `certificateHold` for suspension).

- **Invalidity Date:** When known, the date the key was compromised or the certificate became invalid.

CRL generation is implemented in `src/msp/crl_rfc5280.rs` via `generate_crl_der()`.

7.2.3 CRL Distribution

CRLs are distributed via:

- `/api/v1/crl` – DER format (Content-Type: `application/pkix-crl`)
- `/api/v1/crl/pem` – PEM format (Content-Type: `application/x-pem-file`)

7.3 OCSP Profile

7.3.1 Version Number

OCSP responses conform to RFC 6960 (OCSP v1).

7.3.2 OCSP Extensions

The OCSP responder supports:

- **Nonce:** For replay prevention (when provided in the request).
- **CertID:** Using SHA-256 for issuer name hash and issuer key hash.

7.3.3 OCSP Response Types

The following response types are supported:

- **good** – Certificate is valid and not revoked.
- **revoked** – Certificate has been revoked, with reason code and revocation time.
- **unknown** – Certificate status cannot be determined.

Responses are available in:

- JSON format via `/api/v1/ocsp/query`
 - DER format via `/api/v1/ocsp/query/der`
-

8. Compliance Audit and Other Assessments

8.1 Frequency or Circumstances of Assessment

The CA SHALL undergo compliance assessments:

1. **Annual Audit:** A comprehensive audit of all CP/CPS compliance SHALL be conducted annually by an independent auditor.
2. **Key Ceremony Audit:** Each key ceremony SHALL be audited in real time by an Auditor participant (as required by `KeyCeremony::validate()`).

3. **Incident-Triggered Audit:** A targeted audit SHALL be conducted following any security incident or suspected compromise.

8.2 Identity/Qualifications of Assessor

Auditors SHALL be independent of the CA operational team and possess qualifications in:

- PKI operations and standards (ETSI EN 319 411-1/2, RFC 3647).
- Information security auditing.
- Chilean electronic signature law (Ley 19.799, DS 181, DS 24).

For Chilean PSC accreditation, the auditor SHALL be recognized by the Entidad Acreditadora.

8.3 Assessor's Relationship to Assessed Entity

The assessor SHALL be organizationally independent of the CA. The assessor SHALL not have a financial interest in the CA beyond the audit engagement.

8.4 Topics Covered by Assessment

Audits SHALL cover:

1. Compliance with this CP and the CPS.
2. Physical security of CA facilities.
3. Key management practices, including ceremony records.
4. RA identity proofing procedures and records.
5. Certificate lifecycle operations (issuance, revocation, suspension, renewal).
6. Audit logging completeness and integrity.
7. Disaster recovery readiness.
8. Personnel security and training.
9. Network and system security.

8.5 Actions Taken as a Result of Deficiency

Deficiencies identified during audit SHALL be:

1. Classified by severity (critical, major, minor).
2. Assigned a remediation deadline (critical: 30 days; major: 90 days; minor: 180 days).
3. Tracked to closure with evidence of remediation.
4. Reported to the PKI Policy Authority.

Critical deficiencies MAY result in immediate suspension of CA operations.

8.6 Communication of Results

Audit results SHALL be communicated to:

1. The PKI Policy Authority.

2. The Entidad Acreditadora (for Chilean PSC accreditation).
 3. Relevant supervisory authorities as required by law.
-

9. Other Business and Legal Matters

9.1 Fees

9.1.1 Certificate Issuance or Renewal Fees

Fee schedules for certificate issuance and renewal SHALL be published separately and are not part of this CP.

9.1.2 Certificate Access Fees

Access to certificates, CRLs, and OCSP responses SHALL be free of charge for relying parties.

9.1.3 Revocation or Status Information Access Fees

Revocation and status information SHALL be provided free of charge.

9.1.4 Fees for Other Services

No stipulation.

9.1.5 Refund Policy

No stipulation.

9.2 Financial Responsibility

9.2.1 Insurance Coverage

The CA SHALL maintain professional liability insurance as required by applicable law.

9.2.2 Other Assets

No stipulation.

9.2.3 Insurance or Warranty Coverage for End-Entities

No stipulation.

9.3 Confidentiality of Business Information

9.3.1 Scope of Confidential Information

The following information is considered confidential:

- Subscriber private keys.
- RA identity proofing records (including RUT, legal name, and biometric evidence).
- CA private keys and key ceremony details (beyond the public record hash).
- Audit logs containing personally identifiable information.
- Internal security assessments and vulnerability reports.

9.3.2 Information Not Within the Scope of Confidential Information

The following information is public:

- This CP and the CPS.
- CA certificates.
- CRLs and OCSP responses.
- Certificate serial numbers and public keys.

9.3.3 Responsibility to Protect Confidential Information

All PKI participants SHALL protect confidential information in accordance with applicable privacy and data protection laws.

9.4 Privacy of Personal Information

9.4.1 Privacy Plan

Personal information collected during identity proofing SHALL be processed in accordance with Chilean Ley 19.628 on Protection of Personal Data and, where applicable, EU GDPR.

9.4.2 Information Treated as Private

Personal information includes: legal name, RUT, biometric evidence, contact information, and identity document details.

9.4.3 Information Not Deemed Private

Information included in published certificates (subject name, public key) is not considered private.

9.4.4 Responsibility to Protect Private Information

The CA and RA SHALL implement technical and organizational measures to protect personal information against unauthorized access, disclosure, modification, or destruction.

9.4.5 Notice and Consent for Use of Personal Information

Subscribers SHALL be informed of and consent to the collection and processing of their personal information prior to certificate issuance.

9.4.6 Disclosure Pursuant to Judicial or Administrative Process

Personal information MAY be disclosed pursuant to a valid judicial order or administrative process under Chilean or applicable law.

9.4.7 Other Information Disclosure Circumstances

No stipulation.

9.5 Intellectual Property Rights

No stipulation.

9.6 Representations and Warranties

9.6.1 CA Representations and Warranties

The CA warrants that:

1. Certificates are issued in accordance with this CP and the CPS.
2. Certificates are issued only after successful RA identity verification.
3. CRLs are published within one (1) hour of any revocation event.
4. Audit logs are maintained for seven (7) years.
5. The CA undergoes annual inspection per the Entidad Acreditadora guidelines.

9.6.2 RA Representations and Warranties

The RA warrants that:

1. Subscriber identity is verified per Ley 19.799 Article 15.
2. Chilean RUT is validated via the modulo 11 algorithm.
3. Identity proofing records are retained for seven (7) years.
4. Suspicious identity claims are reported within twenty-four (24) hours.

9.6.3 Subscriber Representations and Warranties

Subscribers warrant that:

1. The private key is protected from unauthorized access.
2. Key compromise is reported within twenty-four (24) hours.
3. Identity information provided to the RA is accurate.
4. The certificate is used only for authorized purposes.

9.6.4 Relying Party Representations and Warranties

Relying parties warrant that they will validate certificates in accordance with Section 4.5.2 before reliance.

9.6.5 Representations and Warranties of Other Participants

No stipulation.

9.7 Disclaimers of Warranties

The CA disclaims all warranties not expressly stated in this CP, to the maximum extent permitted by applicable law.

9.8 Limitations of Liability

The CA's liability is limited to the extent permitted by Ley 19.799 and applicable regulations. The CA shall not be liable for damages arising from reliance on a certificate that was properly validated at the time of use.

9.9 Indemnities

Subscribers SHALL indemnify the CA against claims arising from the subscriber's failure to comply with the obligations stated in Section 9.6.3.

9.10 Term and Termination

9.10.1 Term

This CP becomes effective upon publication and remains in effect until superseded or retired.

9.10.2 Termination

This CP may be terminated by the PKI Policy Authority with ninety (90) days' notice to all affected parties.

9.10.3 Effect of Termination and Survival

Sections 5.4 (Audit Logging), 5.5 (Records Archival), 9.3 (Confidentiality), and 9.4 (Privacy) survive termination of this CP.

9.11 Individual Notices and Communications with Participants

Notices SHALL be communicated via the mechanisms published by the CA.

9.12 Amendments

9.12.1 Procedure for Amendment

Amendments to this CP SHALL be approved by the PKI Policy Authority and published with an incremented version number.

9.12.2 Notification Mechanism and Period

Material amendments SHALL be published at least thirty (30) days before taking effect.

9.12.3 Circumstances Under Which OID Must Be Changed

The CP OID SHALL be changed if amendments materially alter the trust model, assurance levels, or legal framework of the policy.

9.13 Dispute Resolution Provisions

Disputes arising under this CP SHALL be resolved in accordance with Chilean law, with jurisdiction in the courts of Santiago, Chile. Mediation SHALL be attempted before judicial proceedings.

9.14 Governing Law

This CP is governed by the laws of the Republic of Chile, including but not limited to:

- Ley 19.799 – Sobre Documentos Electronicos, Firma Electronica y Servicios de Certificacion
- Decreto Supremo 181/2002 – Reglamento de la Ley 19.799
- Decreto Supremo 24/2019 – Norma Tecnica para Firma Electronica Avanzada

For subscribers and relying parties within the European Union, Regulation (EU) No 910/2014 (eIDAS) applies concurrently. Technical compliance follows:

- ETSI EN 319 411-1 – Policy and security requirements for TSPs issuing certificates (General)
- ETSI EN 319 411-2 – Policy and security requirements for TSPs issuing EU qualified certificates
- ETSI EN 319 412-5 – QCStatements

9.15 Compliance with Applicable Law

The CA SHALL comply with all applicable laws and regulations in the jurisdictions in which it operates.

9.16 Miscellaneous Provisions

9.16.1 Entire Agreement

This CP, together with the CPS, constitutes the entire agreement between the CA and its subscribers regarding certificate services.

9.16.2 Assignment

Rights and obligations under this CP may not be assigned without the prior written consent of the PKI Policy Authority.

9.16.3 Severability

If any provision of this CP is found to be invalid or unenforceable, the remaining provisions shall continue in effect.

9.16.4 Enforcement (Attorneys' Fees and Waiver of Rights)

No stipulation.

9.16.5 Force Majeure

The CA shall not be liable for failure to perform its obligations due to circumstances beyond its reasonable control.

9.17 Other Provisions

No stipulation.

Appendix A: Codebase Module Reference

Module	Path	Function
PKI Core	src/pki.rs	CA hierarchy, certificate issuance, QCStatements, certificatePolicies
PKI Policy	src/pki_policy.rs	OID constants, CP/CPS metadata, certificate profiles, assurance levels
PKI Lifecycle	src/pki_lifecycle.rs	Revocation, suspension, CRL publication, expiry monitoring
PKI Chain	src/pki_chain.rs	X.509 chain validation
PKI Ceremony	src/pki_ceremony.rs	Key ceremony procedure, record integrity

Module	Path	Function
Registration Authority	src/identity/ra.rs	Identity proofing, RUT validation, RA-to-CA certificate issuance
DID	src/identity/did.rs	Canonical DID derivation
Signatures	src/signature/mod.rs	FES/FEA signature levels, biometric evidence, envelope validation
Crypto Module	crates/pqc_crypto_module/	FIPS-oriented cryptographic primitives
OCSP	src/msp/ocsp.rs, src/msp/ocsp_der.rs	OCSP responder
CRL	src/msp/crl_rfc5280.rs	RFC 5280 CRL generation
TSL	src/tsl.rs, src/tsl_client.rs	Trusted Service List client
API Handlers	src/api/handlers/ocsp.rs	OCSP and CRL API endpoints
API Routes	src/api/routes.rs	Route registration for PKI endpoints
Audit	src/audit.rs	Audit logging

Appendix B: Standards Reference

Standard	Description
RFC 3647	Internet X.509 PKI Certificate Policy and CPS Framework
RFC 5280	Internet X.509 PKI Certificate and CRL Profile
RFC 6960	X.509 Internet PKI OCSP
RFC 3161	Internet X.509 PKI Time-Stamp Protocol
FIPS 186-5	Digital Signature Standard (Ed25519)
FIPS 204	Module-Lattice-Based Digital Signature Algorithm (ML-DSA)
FIPS 140-3	Security Requirements for Cryptographic Modules
eIDAS	Regulation (EU) No 910/2014 on electronic identification and trust services
ETSI EN 319 411-1	Policy and security requirements for TSPs issuing certificates (General)
ETSI EN 319 411-2	

Standard	Description
	Policy and security requirements for TSPs issuing EU qualified certificates
ETSI EN 319 412-2	Certificate profiles for natural persons
ETSI EN 319 412-3	Certificate profiles for legal persons
ETSI EN 319 412-4	Certificate profiles for web site certificates
ETSI EN 319 412-5	QCStatements
ETSI TS 102 042	Policy requirements for CAs issuing public key certificates
Ley 19.799	Sobre Documentos Electronicos, Firma Electronica y Servicios de Certificacion
DS 181/2002	Reglamento de la Ley 19.799
DS 24/2019	Norma Tecnica para Firma Electronica Avanzada

End of Document